

HOW TO BUILD A BUSINESS CONTINUITY AND DISASTER RECOVERY PROGRAM

A practical guide to business impact analysis, recovery strategies, crisis management, cyber resilience, testing, and continuous improvement

Alberto (Al) Leiva

Version 1.0 - July 2026

CC BY-NC-SA 4.0

Purpose and responsible-use notice

This manual helps organizations prepare for disruptive events while protecting people, critical services, data, facilities, technology, suppliers, and public trust. Business continuity and disaster recovery decisions should be based on documented business impact, safety, legal obligations, and realistic recovery capabilities.

Table of contents

- 1. Business continuity, disaster recovery, and cyber resilience
- 2. Governance, policy, and accountability
- 3. Program scope and critical-service inventory
- 4. Business impact analysis
- 5. Risk assessment and disruption scenarios
- 6. Recovery objectives: MTPD, RTO, RPO, and WRT
- 7. Continuity and recovery strategies
- 8. Technology disaster recovery
- 9. Data backup and restoration
- 10. Cloud and SaaS resilience
- 11. Cyber incident and ransomware recovery
- 12. Crisis management and communications
- 13. Workforce, facilities, and alternate work
- 14. Supplier and third-party continuity
- 15. Plan development and documentation
- 16. Testing, exercises, and validation
- 17. Metrics, audit evidence, and management review
- 18. Maintenance and continual improvement
- 19. 30/60/90-day implementation roadmap
- 20. Checklists, templates, glossary, and references

1. Business continuity, disaster recovery, and cyber resilience

- Business continuity keeps priority products and services operating at an acceptable level during disruption.
- Disaster recovery restores technology, data, applications, infrastructure, and supporting services.
- Crisis management coordinates leadership decisions, safety, communications, legal obligations, and stakeholder actions.
- Cyber resilience helps systems anticipate, withstand, recover from, and adapt to adverse cyber conditions.
- These disciplines must work together rather than exist as separate documents.

2. Governance, policy, and accountability

- Assign an executive sponsor and a program owner with authority to coordinate business and technology teams.
- Define roles for business owners, IT, cybersecurity, facilities, human resources, legal, privacy, communications, procurement, finance, and suppliers.
- Approve a policy that defines scope, objectives, minimum requirements, testing frequency, reporting, exceptions, and review.
- Identify who may declare a crisis, invoke a plan, approve emergency spending, communicate externally, and return to normal operations.
- Record risk acceptance and unresolved recovery gaps.

3. Program scope and critical-service inventory

- Inventory products, services, business processes, applications, data, facilities, people, equipment, utilities, suppliers, and regulatory commitments.
- Map dependencies and single points of failure.
- Identify minimum viable service levels and acceptable degradation.
- Separate truly critical services from important but deferrable activities.
- Assign an accountable owner and review date to every critical service.

4. Business impact analysis

- Interview process owners and validate results with finance, technology, operations, and leadership.
- Assess impacts over time: safety, customer, legal, financial, operational, reputational, environmental, and societal.
- Document peak periods, deadlines, manual alternatives, dependencies, required records, staffing, and recovery sequence.
- Use quantitative data where available and explain uncertainty.
- Update the BIA after major organizational, technology, supplier, or regulatory changes.

5. Risk assessment and disruption scenarios

- Evaluate natural hazards, utility failures, facility loss, workforce disruption, cyberattack, ransomware, data corruption, supplier failure, cloud outage, telecommunications failure, civil disturbance, and public-health events.
- Consider simultaneous and cascading failures.
- Assess likelihood, impact, warning time, duration, geographic concentration, and recovery complexity.
- Use scenarios to test strategies, not merely to create a risk list.
- Do not assume insurance replaces continuity and recovery capability.

6. Recovery objectives: MTPD, RTO, RPO, and WRT

- Maximum tolerable period of disruption (MTPD) is the longest a process can be unavailable before consequences become unacceptable.
- Recovery time objective (RTO) is the target time to restore a service or resource.
- Recovery point objective (RPO) is the maximum acceptable data loss measured in time.
- Work recovery time (WRT) covers validation, reconciliation, backlog processing, and preparation after technology is restored.
- Recovery objectives must be approved by business owners and supported by tested capabilities.

7. Continuity and recovery strategies

- Select strategies for people, facilities, technology, data, suppliers, communications, finance, and leadership.
- Options include remote work, alternate sites, reciprocal arrangements, redundant systems, manual workarounds, stockpiles, cross-training, alternate suppliers, and geographic diversity.
- Compare cost, recovery speed, capacity, security, complexity, and residual risk.
- Document prerequisites and trigger conditions.
- A strategy is not credible until resources are funded, implemented, and tested.

8. Technology disaster recovery

- Map applications to infrastructure, identity, networks, databases, certificates, DNS, storage, integrations, and suppliers.
- Document recovery order and dependency chains.
- Maintain current architecture diagrams, build procedures, configurations, licenses, credentials, automation, and contact details.
- Separate production administration from recovery administration.
- Test failover, rebuild, restoration, and return-to-primary procedures.
- Define criteria for declaring recovery complete.

9. Data backup and restoration

- Classify data and align backup frequency with approved RPOs.
- Use multiple protected copies and maintain offline or immutable backups for high-risk systems.
- Separate backup credentials and management infrastructure from production compromise paths.
- Encrypt backups, monitor failures, and test restoration.
- Protect SaaS data, configurations, identities, and metadata rather than assuming the provider covers every recovery need.
- Document retention and secure deletion.

10. Cloud and SaaS resilience

- Understand shared responsibility for availability, backups, identity, configuration, and data recovery.
- Design for regional, zonal, account, subscription, and identity-service failures where justified.
- Maintain infrastructure as code and independent copies of critical configurations.
- Review provider service-level commitments, exclusions, incident communications, data export, and exit options.
- Test recovery when the normal cloud console, identity provider, or network connection is unavailable.
- Manage concentration risk across critical providers.

11. Cyber incident and ransomware recovery

- Integrate continuity, disaster recovery, incident response, legal, privacy, communications, and executive decision-making.
- Assume production identity systems, virtualization, backups, monitoring, and communication tools may be affected.
- Preserve evidence while prioritizing safety and service restoration.
- Restore only from verified clean sources and validate security before reconnection.
- Prepare isolated recovery environments and clean administrative credentials.
- Exercise decision-making for prolonged outage, extortion, data theft, and public disclosure.

12. Crisis management and communications

- Maintain a crisis-management team, alternates, contact methods, decision logs, and escalation criteria.
- Prepare internal, customer, supplier, regulator, media, and public communication templates.
- Use verified facts, avoid speculation, and state what is known, unknown, and being done.
- Provide accessible and multilingual communications when needed.
- Maintain out-of-band communication methods.
- Coordinate messages with legal, privacy, security, operations, and executive leadership.

13. Workforce, facilities, and alternate work

- Protect life and safety before service restoration.
- Plan for loss of offices, plants, data centers, call centers, transportation, power, water, and telecommunications.
- Identify minimum staffing, succession, cross-training, travel, remote work, and accommodation needs.
- Provide accessible procedures for employees with disabilities and caregivers.
- Protect emergency access credentials, equipment, and supplies.
- Consider fatigue, mental health, family needs, and sustainable shift coverage during long events.

14. Supplier and third-party continuity

- Identify critical suppliers, subcontractors, logistics providers, cloud services, telecommunications, utilities, and specialized support.
- Review their continuity and disaster recovery capabilities, test evidence, geographic concentration, and financial stability.
- Include notification, recovery, cooperation, data return, exit, and testing requirements in contracts.
- Maintain alternatives for critical goods and services where practical.
- Exercise scenarios involving simultaneous internal and supplier disruption.

15. Plan development and documentation

- Create concise plans for crisis management, business continuity, IT disaster recovery, cyber recovery, communications, facilities, and suppliers.
- Each plan should include purpose, scope, assumptions, triggers, roles, contacts, actions, dependencies, workarounds, recovery steps, validation, and return to normal.
- Use checklists and decision trees for stressful conditions.
- Store protected online and offline copies.
- Control versions and remove obsolete plans.

16. Testing, exercises, and validation

- Use document reviews, call-tree tests, tabletop exercises, technical restoration tests, simulations, failovers, and full operational exercises.
- Test people, decisions, technology, suppliers, communications, facilities, and evidence collection.
- Define objectives, scope, safety limits, success criteria, observers, and rollback.
- Record gaps, owners, due dates, and retest evidence.
- Do not claim recovery capability solely because a plan exists.

17. Metrics, audit evidence, and management review

- Track BIA coverage, approved objectives, plan currency, exercise completion, restoration success, unresolved gaps, backup failures, supplier coverage, and training.
- Compare demonstrated recovery performance with approved RTO and RPO.
- Report critical assumptions and concentration risks.
- Retain policies, BIAs, plans, approvals, exercise records, restoration evidence, lessons learned, corrective actions, and management decisions.
- Use management review to approve priorities, resources, and risk acceptance.

18. Maintenance and continual improvement

- Review plans after exercises, incidents, reorganizations, acquisitions, migrations, supplier changes, and regulatory changes.
- Validate contact lists and technical procedures regularly.
- Track corrective actions to evidence-based closure.
- Use lessons learned without blaming individuals.
- Retire obsolete systems, dependencies, credentials, and documents.
- Include climate-related disruption considerations in the organizational context where relevant.

19. 30/60/90-day implementation roadmap

- Days 1-30: establish governance, identify top critical services, complete rapid BIAs, validate contacts, review backups, and identify major single points of failure.
- Days 31-60: approve recovery objectives, document strategies, update crisis and recovery plans, establish out-of-band communications, and begin supplier reviews.
- Days 61-90: conduct tabletop and restoration exercises, close critical gaps, establish metrics, automate plan reminders, and complete management review.

20. Checklists, templates, glossary, and references

Production readiness checklist

- ☐ Executive sponsor and program owner assigned
- ☐ Critical services and dependencies inventoried
- ☐ Business impact analysis approved
- ☐ MTPD, RTO, RPO, and WRT defined
- ☐ Recovery strategies funded and implemented
- ☐ Crisis authority and communication channels documented

- ☐ Technology recovery sequence validated
- ☐ Offline or immutable backups protected
- ☐ Cloud and supplier dependencies assessed
- ☐ Ransomware recovery environment prepared
- ☐ Accessible workforce and alternate-site procedures documented
- ☐ Plans stored online and offline
- ☐ Tabletop and restoration tests completed
- ☐ Corrective actions tracked to closure
- ☐ Management review and residual-risk acceptance recorded

Sample business impact analysis fields

Field	Example
Service	Customer payment processing
Owner	Finance Operations
Minimum acceptable level	Priority payments only
MTPD	24 hours
RTO	4 hours
RPO	15 minutes
WRT	2 hours
Peak period	Month end
Dependencies	Identity, network, payment gateway, database, bank
Manual workaround	Limited emergency approval workflow
Safety / legal impact	Contractual and regulatory reporting
Recovery priority	Tier 1

Glossary

Term	Definition
BCMS	Business continuity management system.
BIA	Business impact analysis.
MTPD	Maximum tolerable period of disruption.
RTO	Target time to restore a service.
RPO	Maximum acceptable data loss measured in time.
WRT	Time needed to validate, reconcile, and resume work after technical recovery.
Failover	Transfer of service to an alternate capability.
Failback	Controlled return to the primary capability.
Crisis management	Leadership coordination during a major

	disruption.
Cyber resilience	Ability to anticipate, withstand, recover from, and adapt to cyber adversity.

Official references

- NIST SP 800-34 Rev. 1 - Contingency Planning Guide for Federal Information Systems: <https://csrc.nist.gov/pubs/sp/800/34/r1/upd1/final>
- NIST SP 800-160 Vol. 2 Rev. 1 - Developing Cyber-Resilient Systems: <https://csrc.nist.gov/pubs/sp/800/160/v2/r1/final>
- NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>
- ISO 22301:2019 - Business Continuity Management Systems: <https://www.iso.org/standard/75106.html>
- ISO 22301:2019/Amd 1:2024 - Climate Action Changes: <https://www.iso.org/standard/88412.html>

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.